



RED TEAM

INTERNSHIP ENGAGEMENT REPORT

Week 02: Network Enumeration & Service Vulnerability Discovery

Organization	CyberSter
Report Title	Network Enumeration & Service Vulnerability Discovery
Student Name	Daniyal Shahid
Roll No.	CYB-INT-HQYINF
Instructor	Umar Niaz
Batch	2026
Target	Authorized Metasploitable 2 practice environment
Date	Thursday, July 2, 2026

⚠ CONFIDENTIAL - FOR INTERNAL TRAINING USE ONLY ⚠

Table of Contents

1. EXECUTIVE SUMMARY	2
2. INTRODUCTION	2
3. METHODOLOGY OVERVIEW	3
ASSESSMENT LIFECYCLE	3
TASK 01 Advanced Network Scanning with Nmap	3
4.1 - TASK OVERVIEW	4
4.2 - TOOLS USED & WHY	4
4.3 - COMMANDS & EXECUTION	4
4.4 - KEY FINDINGS	7
4.5 - ANALYSIS & IMPACT	7
TASK 02 Service Fingerprinting & Banner Grabbing	8
5.1 - TASK OVERVIEW	8
5.2 - TOOLS USED & WHY	8
5.3 - COMMANDS & EXECUTION	8
5.4 - Summary of Findings & Recommended Tools	11
5.5 - ANALYSIS & IMPACT	12
TASK 03 Leveraging Nmap Scripting Engine (NSE)	12
6.1 - TASK OVERVIEW	12
6.2 - TOOLS USED & WHY	12
6.3 - COMMANDS & EXECUTION	13
6.4 - KEY FINDINGS	15
6.5 - ALTERNATIVE TOOLS	16
6.6 - ANALYSIS & IMPACT	16
TASK 04 Stealth & Firewall Evasion Techniques	17
7.1 - TASK OVERVIEW	17
7.2 - TOOLS USED & WHY	17
7.3 - COMMANDS & EXECUTION	18
7.4 - KEY FINDINGS	23
7.5 - ANALYSIS & IMPACT	23
8. KEY FINDINGS SUMMARY	24
9. RISK ASSESSMENT	24
10. RECOMMENDATIONS	25
11. CONCLUSION	25
12. APPENDIX - COMMANDS REFERENCE	25

1. EXECUTIVE SUMMARY

This report documents the practical completion of all assignments for **Week 02** of the Cybersecurity Internship at CyberSter, under the instruction of **Umar Niaz**. The objective of this week was to transition from basic reconnaissance to professional-grade vulnerability assessment and attack surface analysis against the **authorized Metasploitable 2 practice environment**.

A comprehensive assessment was conducted to identify security gaps within the target infrastructure. This included deep-packet service enumeration, SMB version identification, and script-based vulnerability scanning to detect known exposures such as legacy protocol weaknesses and misconfigured services. The assessment utilized advanced diagnostic tools, including Nmap for tactical service fingerprinting and automated vulnerability script engines, to map the attack surface effectively.

This report provides a detailed documentation of the security posture of the target machine, including all terminal commands executed, full annotated outputs, and a systematic analysis of the identified services. All activities were restricted to an authorized sandbox environment, focusing on diagnostic mapping and vulnerability identification without executing intrusive exploitation. The findings documented here establish the necessary intelligence for subsequent phases of the security assessment.

2. INTRODUCTION

This assessment was completed as part of the Week 02 Cybersecurity Internship at CyberSter, under the supervision of Umar Niaz. The target for this phase was an authorized Metasploitable 2 practice environment, serving as a legally authorized environment for advanced ethical hacking and vulnerability assessment. This phase serves as a foundational step for future exploitation analysis, focusing on high-accuracy data gathering. The objective for Week 02 was to transition from passive discovery to active service enumeration and vulnerability identification, aiming to map the target's attack surface through tactical technical analysis.

The scope was strictly defined to focus on service-level interrogation, protocol analysis, and the identification of potentially insecure configurations. All activities were confined to non-intrusive diagnostic scanning, utilizing professional enumeration techniques to extract actionable intelligence regarding the target's operational services and patch levels. This constraint ensures that the operator develops the precision required to identify high-value security gaps while maintaining the integrity and stability of the target environment during the reconnaissance and assessment lifecycle.

Target: Authorized Metasploitable 2 practice environment

Scope: Active Service Enumeration, Protocol Analysis, and Vulnerability Assessment.

Instructor: Umar Niaz, Red Team Instructor at CyberSter

Student: Daniyal Shahid | CYB-INT-HQYINF | Batch 2026

3. METHODOLOGY OVERVIEW

A disciplined, structured methodology was applied to assess the target **Metasploitable 2** environment. The approach transitioned from standard reconnaissance to active network enumeration, service fingerprinting, and firewall evasion analysis across four technical phases. The methodology followed a structured security assessment lifecycle: **Network Scanning** → **Service Fingerprinting** → **Vulnerability Assessment** → **Evasion Testing**.

ASSESSMENT LIFECYCLE

- **Advanced Network Scanning:** Transitioning from broad reconnaissance to targeted TCP/UDP scanning, comparing stealth (-sS) and connect (-sT) scan mechanics.
- **Service Fingerprinting:** Tactical analysis of service banners, headers, and protocol-specific probes using Nmap Version Detection (-sV) to identify precise software implementations.
- **Manual Banner Grabbing:** Direct interaction with open services (FTP, HTTP, SMTP) using Netcat (nc) and Telnet to verify service headers and protocol features.
- **Vulnerability Mapping:** Utilization of the Nmap Scripting Engine (NSE) to automate the detection of exploitable vulnerabilities and mapping results to specific CVE IDs.
- **SMB & Protocol Enumeration:** Deep inspection of critical network protocols, specifically using Enum4linux for SMB share, user, and group identification.
- **Firewall & IDS Evasion:** Practical application of packet fragmentation, MTU manipulation, Decoy scanning, and source port spoofing to analyze network security appliance behavior.
- **Security Posture Documentation:** Structured logging of all scan results, service versions, and identified vulnerabilities to establish a reliable baseline of the target's attack surface.
- **Cross-Validation:** Systematic comparison of timing templates (-T2 vs -T4) and scan flags to evaluate visibility versus scan reliability.

TASK 01 Advanced Network Scanning with Nmap

Objective: To transition from broad reconnaissance to targeted network scanning, identifying open ports, and fingerprinting services while avoiding basic security triggers.

Engagement Phase: Active Network Enumeration - Direct diagnostic interaction with the authorized Metasploitable 2 environment.

4.1 - TASK OVERVIEW

Transitioning from broad reconnaissance to targeted network scanning is critical for understanding the target's live attack surface. This task focused on mapping open ports and identifying listening services on the Metasploitable 2 environment while analyzing the impact of different scan types, timing templates, and stealth techniques on detection and reliability.

4.2 - TOOLS USED & WHY

Nmap: The industry-standard tool for network discovery and security auditing. Used here for its versatility in TCP/UDP scanning, timing control, and OS/service fingerprinting capabilities.

Linux Terminal: Used for command execution, logging, and output parsing to file (-oN).

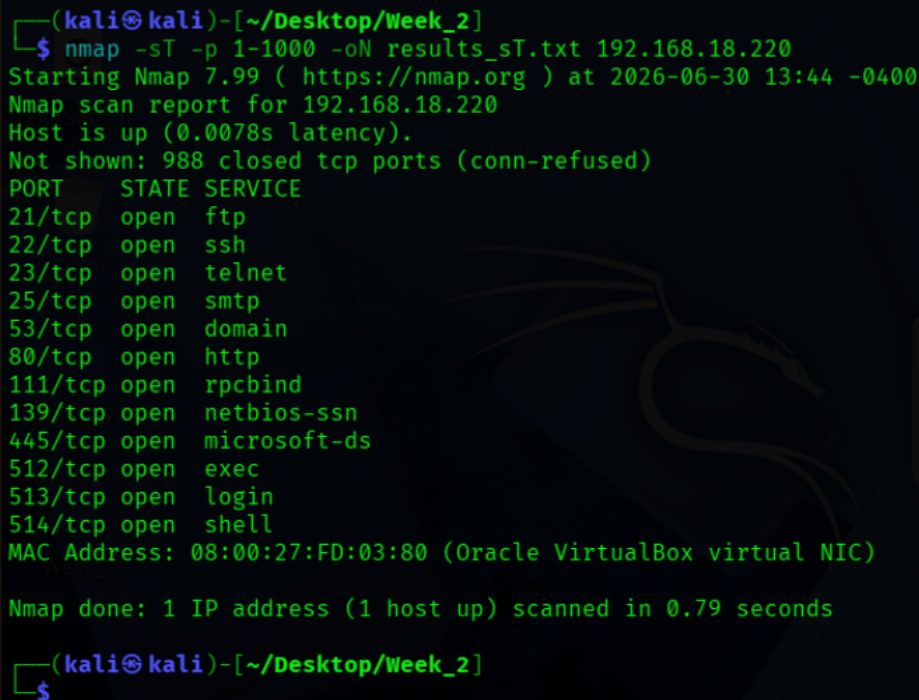
4.3 - COMMANDS & EXECUTION

Step 1 - TCP Connect vs. SYN Stealth Scan

```
# TCP Connect Scan (-sT)
nmap -sT -p 1-1000 -oN results_sT.txt 192.168.18.220

# SYN Stealth Scan (-sS)
sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.18.220
```

Screenshot: Screenshot of Nmap output showing open ports for both scans



```
(kali㉿kali)-[~/Desktop/Week_2]
└─$ nmap -sT -p 1-1000 -oN results_sT.txt 192.168.18.220
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-30 13:44 -0400
Nmap scan report for 192.168.18.220
Host is up (0.0078s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 08:00:27:FD:03:80 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.79 seconds

(kali㉿kali)-[~/Desktop/Week_2]
└─$
```

```
(kali㉿kali)-[~/Desktop/Week_2]
$ sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.18.220
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-30 13:45 -0400
Nmap scan report for 192.168.18.220
Host is up (0.0029s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 08:00:27:FD:03:80 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.97 seconds

(kali㉿kali)-[~/Desktop/Week_2]
$
```

Step 2 - UDP Service Scanning

```
sudo nmap -sU --top-ports 100 -oN results_udp.txt 192.168.18.220
```

Screenshot: Screenshot of UDP scan results

```
(kali㉿kali)-[~/Desktop/Week_2]
$ sudo nmap -sU --top-ports 100 -oN results_udp.txt 192.168.18.220
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-30 13:45 -0400
Nmap scan report for 192.168.18.220
Host is up (0.018s latency).
Not shown: 93 closed udp ports (port-unreach)
PORT      STATE SERVICE
53/udp    open  domain
68/udp    open|filtered dhcpc
69/udp    open|filtered tftp
111/udp   open  rpcbind
137/udp   open  netbios-ns
138/udp   open|filtered netbios-dgm
2049/udp  open  nfs
MAC Address: 08:00:27:FD:03:80 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 113.56 seconds

(kali㉿kali)-[~/Desktop/Week_2]
$ █
```

Step 3 - Timing Template Analysis (-T2 vs -T4)

```
# Aggressive Scan
sudo nmap -sS -T4 -p 1-1000 -oN sS_T4.txt 192.168.18.220

# Polite/Stealthier Scan
sudo nmap -sS -T2 -p 1-1000 -oN sS_T2.txt 192.168.18.220
```

Screenshot: Screenshot of Timing Template Analysis (Aggressive VS Polite)

```
(kali㉿kali)-[~/Desktop/Week_2]
$ sudo nmap -sS -T4 -p 1-1000 -oN sS_T4.txt 192.168.18.220
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-30 13:50 -0400
Nmap scan report for 192.168.18.220
Host is up (0.0045s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 08:00:27:FD:03:80 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.37 seconds

(kali㉿kali)-[~/Desktop/Week_2]
$
```

```
(kali㉿kali)-[~/Desktop/Week_2]
$ sudo nmap -sS -T2 -p 1-1000 -oN sS_T2.txt 192.168.18.220
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-30 13:50 -0400
Stats: 0:05:11 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 52.17% done; ETC: 14:00 (0:04:44 remaining)
Nmap scan report for 192.168.18.220
Host is up (0.012s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 08:00:27:FD:03:80 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 503.26 seconds

(kali㉿kali)-[~/Desktop/Week_2]
$
```

4.4 - KEY FINDINGS

Finding	Description	Evidence Source
Open TCP Services	Identified 12 open TCP ports (FTP, SSH, Telnet, SMTP, Domain, HTTP, RPCBind, NetBIOS-ssn, Microsoft-ds, Exec, Login, Shell).	results_sS.txt
UDP Surface	Discovered 7 UDP services, including Domain, RPCBind, NFS, NetBIOS-ns, and DHCP/TFTP/NetBIOS-dgm states.	results_udp.txt
Scan Reliability	TCP Connect (-sT) and SYN Stealth (-sS) produced identical results, confirming no active filter drops half-open connections.	Scan Comparison
Timing Efficiency	Significant duration variance observed: -T4 (2.37s) vs -T2 (503.26s), highlighting the trade-off between scan speed and stealth.	Timing Logs
Host Context	Target confirmed as an Oracle VirtualBox virtual machine.	MAC Address

4.5 - ANALYSIS & IMPACT

Visibility Analysis: The consistency between -sT and -sS scans indicates the absence of restrictive firewalls that would otherwise disrupt half-open connections.

Operational Security: From a Red Team perspective, the -T2 timing template is significantly more "polite," reducing the risk of triggering IDS/IPS alerts, whereas -T4 is optimized for rapid mapping in authorized environments.

Attack Surface: The presence of 12 open TCP ports and multiple critical UDP services (e.g., NFS, RPCBind) presents a wide attack surface, providing numerous vectors for service-level exploitation and privilege escalation.

RED TEAM INSIGHT

In professional red team operations, scanning is not a "one-size-fits-all" process. While an aggressive scan (-T4) provides rapid visibility into the attack surface, it is often too "loud" for stealthy environments where IDS/IPS systems are active. Conversely, slower timing templates (-T2) allow for more polite, low-profile enumeration that is less likely to trigger security alarms, albeit at the cost of significantly increased scan duration.

Furthermore, the consistency between TCP Connect (-sT) and SYN Stealth (-sS) scans serves as a valuable indicator of the target's perimeter security; identical results suggest a lack of aggressive firewall filtering for half-open connections. Relying on a single scan type or timing configuration limits an operator's situational awareness. A multi-layered approach combining broad discovery with targeted, protocol-specific enumeration is essential to build a reliable and actionable baseline of the target's infrastructure before moving to the exploitation phase.

TASK 02 Service Fingerprinting & Banner Grabbing

Objective: Identify the exact versions of services running on open ports to look for known vulnerabilities and map them to potential exploits.

Engagement Phase: Active Service Enumeration - Performing protocol-specific probes and manual interaction with identified services.

5.1 - TASK OVERVIEW

Identifying open ports is only the first step of reconnaissance. To move toward effective vulnerability assessment, an operator must determine the specific software and versions running on those ports. This task focused on service-level interrogation using active fingerprinting probes and manual banner grabbing to identify the exact service implementations, which act as the "keys" to mapping specific CVEs.

5.2 - TOOLS USED & WHY

Nmap (-sV): Used for automated service version detection by sending protocol-specific probes and analyzing responses against a fingerprint database.

Nmap (-A): Employed for aggressive scanning to combine OS detection, version detection, script scanning, and traceroute into a single comprehensive output.

Netcat (nc): Utilized for manual banner grabbing, allowing for direct interaction with services to retrieve hidden headers or login banners that automated tools might miss.

Enum4linux: Used specifically for deep enumeration of SMB (Port 445), including share listing, user enumeration, and workgroup identification.

5.3 - COMMANDS & EXECUTION

Version Detection:

```
nmap -sV 192.168.18.220
```

Screenshot: Version Detection

```

(kali@kali)-[~/Desktop/Week_2/detection]
└─$ nmap -sV 192.168.18.220 -oN Version_detection.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-30 14:22 -0400
Nmap scan report for 192.168.18.220
Host is up (0.0033s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:FD:03:80 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.80 seconds

```

Aggressive Scan:

```
sudo nmap -A 192.168.18.220
```

Screenshot: Aggressive Scan

```

(kali@kali)-[~/Desktop/Week_2/detection]
└─$ sudo nmap -A 192.168.18.220 -oN Aggressive.txt
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-30 14:26 -0400
Nmap scan report for 192.168.18.220
Host is up (0.0028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.18.231
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvince
outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45

```

Manual Banner Grabbing

```
# FTP
nc 192.168.18.220 21
# SSH Access with Legacy RSA Compatibility
ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa
msfadmin@192.168.18.98
```

Screenshot: Manual Banner Grabbing

FTP (File Transfer Protocol) Port: 21

```
(kali㉿kali)-[~/Desktop/Week_2/detection]
$ nc 192.168.18.220 21
220 (vsFTPD 2.3.4)
USER anonymous
331 Please specify the password.
PASS anonymous@example.com
230 Login successful.
SYST
215 UNIX Type: L8
QUIT
221 Goodbye.
```

SSH (Secure Shel) Port: 22

```
(kali㉿kali)-[~/Desktop/Week_2/detection]
$ nc 192.168.18.220 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

```
(kali㉿kali)-[~/Desktop/Week_2/detection]
$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.18.94
The authenticity of host '192.168.18.94 (192.168.18.94)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9Gci0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.18.94' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.18.94's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Wed Jul 1 03:51:21 2026
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$
```

SMB Enumeration:

```
enum4linux -a 192.168.18.220
```

Screenshot: Screenshot of SMB Enumeration

```
(kali@kali)-[~/Desktop/Week_2/detection]
$ enum4linux -a 192.168.18.94
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Jul 1 04:00:53 2026

===== ( Target Information ) =====

Target ..... 192.168.18.94
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.18.94 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.18.94 ) =====

Looking up status of 192.168.18.94
  METASPLOITABLE <00> - B <ACTIVE> Workstation Service
  METASPLOITABLE <03> - B <ACTIVE> Messenger Service
  METASPLOITABLE <20> - B <ACTIVE> File Server Service
  .._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
  WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
  WORKGROUP <1d> - B <ACTIVE> Master Browser
  WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

  MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.18.94 ) =====
```

5.4 - Summary of Findings & Recommended Tools

Category	Finding / Tool	Description
Critical Findings	Port 1524	Open root bindshell accessible directly via telnet/netcat.
Critical Findings	Port 21 (vsftpd)	Vulnerable to backdoor command execution.
Critical Findings	Port 6667 (UnrealIRCd)	Known backdoor allowing remote command execution.
Authentication	Anonymous FTP	Allows access without credentials (code 230).
Alternative Tool	Metasploit (msfconsole)	Primary framework for automating service-specific exploits.
Alternative Tool	Nikto	Used to scan web servers (80/8180) for vulnerabilities.

Alternative Tool	Hydra	Essential for brute-forcing services like SSH, MySQL, or Telnet.
Alternative Tool	Nmap NSE	Use the --script vuln flag to identify specific CVEs.

5.5 - ANALYSIS & IMPACT

The target system presents a highly critical risk profile due to its extensive attack surface and the presence of multiple services running with root-level privileges. Because the machine allows null sessions via SMB and contains several hardcoded backdoors such as the bindshell on port 1524 and the vsftpd exploit the barrier to achieving a full system compromise is effectively non-existent. This environment is intentionally insecure, and the combination of outdated database versions and cleartext authentication protocols makes it a prime candidate for immediate, high-fidelity exploitation.

RED TEAM INSIGHT

From a penetration testing perspective, this host serves as the perfect entry point for deeper network infiltration. By exploiting the existing vulnerabilities to gain root access, a red team operator can easily pivot to perform internal reconnaissance or launch attacks against other systems within the 192.168.18.0/24 subnet. The ability to move laterally from this machine is significantly elevated because the compromised service configurations provide a stable, persistent foothold that can be used to bypass traditional network perimeter defenses.

TASK 03 Leveraging Nmap Scripting Engine (NSE)

Objective: To utilize automated scripts to detect vulnerabilities and misconfigurations during the scanning process.

Engagement Phase: This phase follows initial enumeration it shifts focus from identifying open ports to actively discovering service-specific security weaknesses using the Nmap Scripting Engine.

6.1 - TASK OVERVIEW

The Nmap Scripting Engine (NSE) allows for a deeper analysis of the target system than simple port scanning provides. This task focused on using automated scripts from the 'Discovery', 'Safe', and 'Vuln' categories to gather additional information about services and identify exploitable vulnerabilities. By mapping NSE output to specific CVE IDs, an operator can effectively automate the repetitive parts of vulnerability discovery and gain actionable intelligence for further exploitation.

6.2 - TOOLS USED & WHY

Nmap Scripting Engine (NSE): This is the primary tool used because it contains specialized scripts that help gather advanced information about services, such as directory structures, SSL certificate details, and potential security flaws that cannot be identified through basic port scanning.

Vulnerability Category Scripts (--script vuln): These scripts are utilized to perform automated vulnerability detection against the target, mapping detected weaknesses directly to specific CVE IDs to streamline the exploitation process.

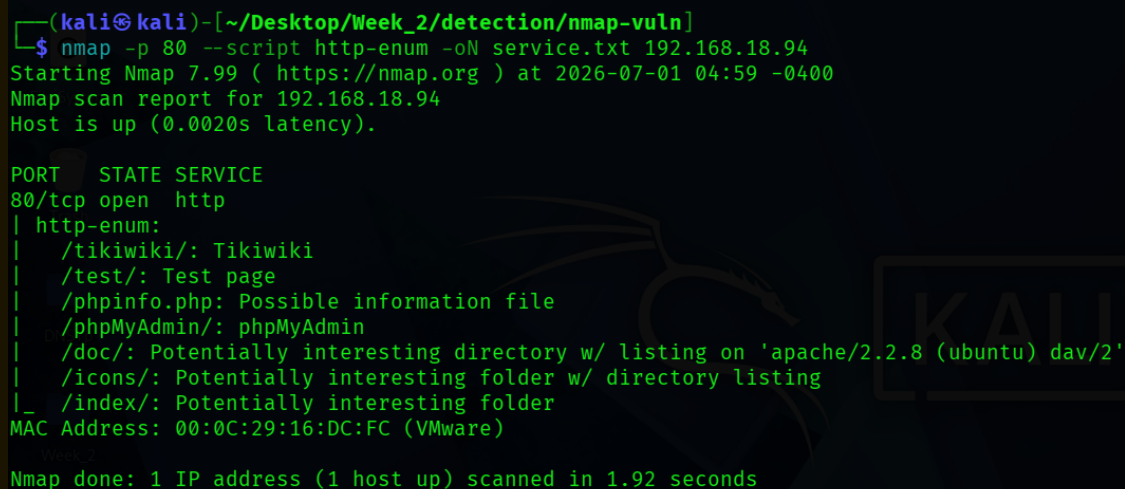
Discovery & Safe Category Scripts: These are used to collect extra information (e.g., DNS data, HTTP headers) and perform service checks that are unlikely to disrupt or crash the target services, ensuring the scan remains safe and controlled.

6.3 - COMMANDS & EXECUTION

HTTP Service Enumeration

```
# Execute to enumerate common web directories
nmap -p 80 --script http-enum 192.168.18.94
# Purpose: Identify /admin, /login, /uploads, etc.
```

Screenshot: Http Service directory listing



```
(kali@kali) - [~/Desktop/Week_2/detection/nmap-vuln]
$ nmap -p 80 --script http-enum -oN service.txt 192.168.18.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 04:59 -0400
Nmap scan report for 192.168.18.94
Host is up (0.0020s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
| /tikiki/: Tikiwiki
| /test/: Test page
| /phpinfo.php: Possible information file
| /phpMyAdmin/: phpMyAdmin
| /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
| /icons/: Potentially interesting folder w/ directory listing
|_ /index/: Potentially interesting folder
MAC Address: 00:0C:29:16:DC:FC (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.92 seconds
```

Comprehensive Vulnerability Scan

```
# Execute to perform vulnerability scanning on target services
sudo nmap -sV --script vuln 192.168.18.94

# Purpose: Detect known vulnerabilities in running services and retrieve
associated CVE identifiers where applicable.
```

Screenshot: Comprehensive Vulnerability Scan

```
(kali@kali)-[~/Desktop/Week_2/detection/nmap-vuln]
$ sudo nmap -sV --script vuln -oN scan.txt 192.168.18.94
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 05:00 -0400
Stats: 0:00:46 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.66% done; ETC: 05:01 (0:00:00 remaining)
Stats: 0:04:13 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.90% done; ETC: 05:04 (0:00:00 remaining)
Stats: 0:06:13 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.93% done; ETC: 05:06 (0:00:00 remaining)
Nmap scan report for 192.168.18.94
Host is up (0.0036s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
vsftpd    2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs: CVE:CVE-2011-2523 BID:48539
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   https://www.securityfocus.com/bid/48539
```

SSL/TLS Certificate Discovery

```
# Execute to retrieve SSL/TLS certificate details from HTTPS service
nmap -p 443 --script ssl-cert 192.168.18.94
```

Purpose: Extract SSL/TLS certificate details including issuer, subject, and expiry date to verify authenticity and security configuration.

SSL/TLS certificate enumeration was performed on target system. However, port 443 was found closed, indicating that HTTPS service is not running. Therefore, no SSL certificate information could be retrieved.

Screenshot: SSL/TLS Certificate Discovery

```
(kali@kali)-[~/Desktop/Week_2/detection/nmap-vuln]
$ nmap -p 443 --script ssl-cert 192.168.18.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 05:08 -0400
Nmap scan report for 192.168.18.94
Host is up (0.00071s latency).

PORT      STATE SERVICE
443/tcp    closed https
MAC Address: 00:0C:29:16:DC:FC (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.75 seconds

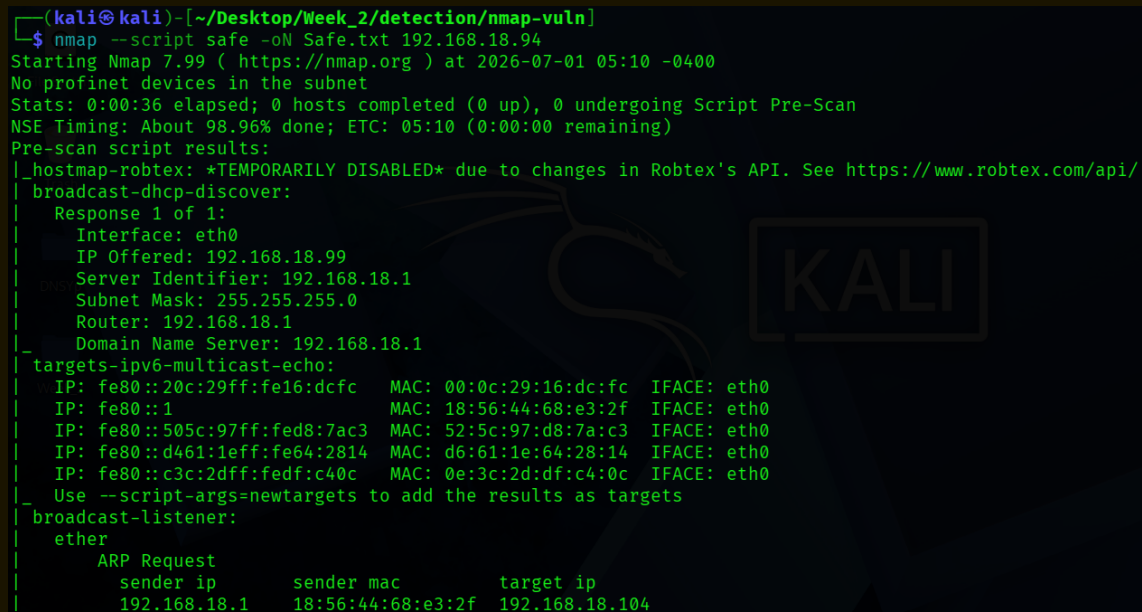
(kali@kali)-[~/Desktop/Week_2/detection/nmap-vuln]
$ █
```

Running Discovery & Safe Scripts

```
# Execute to perform non-intrusive network information gathering
nmap --script safe 192.168.18.94

# Purpose: Perform non-disruptive checks to collect safe system information such
as service banners, HTTP headers, and general network configuration.
```

Screenshot: Safe Network Discovery & Security Checks



```
(kali㉿kali)-[~/Desktop/Week_2/detection/nmap-vuln]
$ nmap --script safe -oN Safe.txt 192.168.18.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 05:10 -0400
No profinet devices in the subnet
Stats: 0:00:36 elapsed; 0 hosts completed (0 up), 0 undergoing Script Pre-Scan
NSE Timing: About 98.96% done; ETC: 05:10 (0:00:00 remaining)
Pre-scan script results:
|_ hostmap-robtext: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtext.com/api/
| broadcast-dhcp-discover:
|   Response 1 of 1:
|     Interface: eth0
|     IP Offered: 192.168.18.99
|     Server Identifier: 192.168.18.1
|     Subnet Mask: 255.255.255.0
|     Router: 192.168.18.1
|     Domain Name Server: 192.168.18.1
|_ targets-ipv6-multicast-echo:
|   IP: fe80::20c:29ff:fe16:dcfc   MAC: 00:0c:29:16:dc:fc   IFACE: eth0
|   IP: fe80::1                  MAC: 18:56:44:68:e3:2f   IFACE: eth0
|   IP: fe80::505c:97ff:fed8:7ac3 MAC: 52:5c:97:d8:7a:c3   IFACE: eth0
|   IP: fe80::d461:1eff:fe64:2814 MAC: d6:61:1e:64:28:14   IFACE: eth0
|   IP: fe80::c3c:2dff:fedf:c40c   MAC: 0e:3c:2d:df:c4:0c   IFACE: eth0
|   Use --script-args=newtargets to add the results as targets
| broadcast-listener:
|   ether
|     ARP Request
|       sender ip      sender mac      target ip
|       192.168.18.1   18:56:44:68:e3:2f   192.168.18.104
```

6.4 - KEY FINDINGS

Port	Service	Vulnerability / Issue	Criticality
21	FTP	vsFTPD 2.3.4 Backdoor (CVE-2011-2523)	Critical
22	SSH	Multiple CVEs (e.g., CVE-2023-38408, CVE-2016-1908)	High
25	SMTP	SSL POODLE, Logjam (DHE_EXPORT), Weak DH	High
53	DNS	ISC BIND 9.4.2 (Various remote exploit vectors)	High
80	HTTP	Apache 2.2.8; Slowloris DoS (CVE-2007-6750)	Medium

6.5 - ALTERNATIVE TOOLS

Alternative Tool	Purpose	Comparison vs Primary (Nmap)
Hydra	Credential brute-forcing	Nmap identifies the service; Hydra actively attempts to crack credentials.
Metasploit	Manual exploit execution	Nmap detects the vulnerability (e.g., vsFTPD backdoor); Metasploit provides the module to exploit it.
Nessus / OpenVAS	Vulnerability assessment	Nmap is for discovery; these tools run comprehensive scans against known CVE databases.
Testssl.sh	TLS/SSL configuration analysis	Nmap identifies the port is open; this tool performs a deep audit of cipher suites and protocol security.
Nikto	Web server vulnerability scanning	Nmap confirms HTTP is running; Nikto identifies specific web-level misconfigurations and vulnerable files.
OWASP ZAP	Web application penetration testing	Nmap covers the transport layer; ZAP analyzes the actual web application logic for vulnerabilities.

Category	Tool / Approach	Purpose / Recommendation
Comprehensive Vulnerability Assessment	Nessus / OpenVAS	Recommended for full system-wide vulnerability assessment. These tools automatically detect legacy vulnerabilities, misconfigurations, and missing patches more effectively than manual scanning.
Web Application Security Testing	OWASP ZAP	Industry-standard tool for identifying web application vulnerabilities such as SQL injection, XSS, and insecure configurations that traditional port scanners cannot detect.

6.6 - ANALYSIS & IMPACT

The target system is running highly outdated services, most notably **vsFTPD 2.3.4**, which contains a well-documented backdoor allowing for trivial remote code execution with root privileges. The presence of **Apache 2.2.8** and **ISC BIND 9.4.2** further exposes the host to numerous legacy exploits and denial-of-service vectors. The SMTP service is also misconfigured, supporting insecure protocols and weak Diffie-Hellman groups, which facilitates man-in-the-middle (MitM) attacks. Collectively, these vulnerabilities indicate a system that has not been patched for over a decade, providing multiple paths for complete system compromise and lateral movement within the network.

RED TEAM INSIGHT

From an offensive perspective, this host is a "low-hanging fruit" target. The exploit path is straightforward: utilizing the vsFTPD backdoor provides immediate root-level access, bypassing the need for complex credential harvesting or advanced exploitation of the other services. Once root access is achieved, the attacker can easily dump local hashes from the SSH or system files to escalate privileges or move laterally into the 192.168.18.0/24 subnet, as evidenced by the internal network traffic captured during the scan. Defensive efforts should prioritize immediate system decommissioning or a complete re-build, as patching such an end-of-life stack is likely insufficient.

TASK 04 Stealth & Firewall Evasion Techniques

Objective: To practice evasion techniques that bypass basic Intrusion Detection Systems (IDS) and firewalls. The goal is to learn that while "loud" scans are easily blocked, "quiet" and "creative" scan adjustments such as packet fragmentation, MTU manipulation, decoy IP generation, and source port spoofing can effectively slip past simple packet filters and trusted-port rules.

Engagement Phase: The process involves conducting three primary categories of evasion tests against an authorized lab target:

- **Packet Fragmentation and MTU Manipulation:** Using -f to split scan packets into smaller fragments and --mtu 16 to force small packet sizes, testing how the network stack handles fragmented traffic.
- **Decoy Scanning:** Using -D RND:5 (or 10) to insert fake source IP addresses alongside the real scanner, making it difficult for the target to identify the actual source of the scan.
- **Source Port Manipulation:** Using --source-port 53 to make the scan appear as though it originates from a trusted DNS port, testing the ability to bypass firewall rules that only permit traffic from specific services.
- **Documentation:** Recording the scan time, ports found, and specific observations for each command to analyze which methods are "stealthy" versus "noisy".

7.1 - TASK OVERVIEW

The objective of this task is to practice evasion techniques designed to bypass basic Intrusion Detection Systems (IDS) and firewalls. By adjusting how scan packets are sent specifically through packet fragmentation, MTU manipulation, decoy IP generation, and source port spoofing security testers can observe how network defenses react to these modifications. The primary learning goal is to understand that while "loud" scans are easily blocked by security triggers, "quiet" and "creative" scans are often more effective at achieving results in a red teaming engagement.

7.2 - TOOLS USED & WHY

Nmap: This is the primary tool for this task because it features built-in flags specifically designed for advanced packet crafting, which allows for testing various evasion and stealth techniques against network defenses.

Hping3 (Alternative): This tool is used for advanced packet crafting, providing deeper control over TCP/IP packets to test firewall responses beyond the capabilities of standard port scanners.

Scapy (Alternative): This is a powerful Python-based library used to create custom, complex packets, which is highly effective when specific, non-standard evasion techniques are required during a security assessment

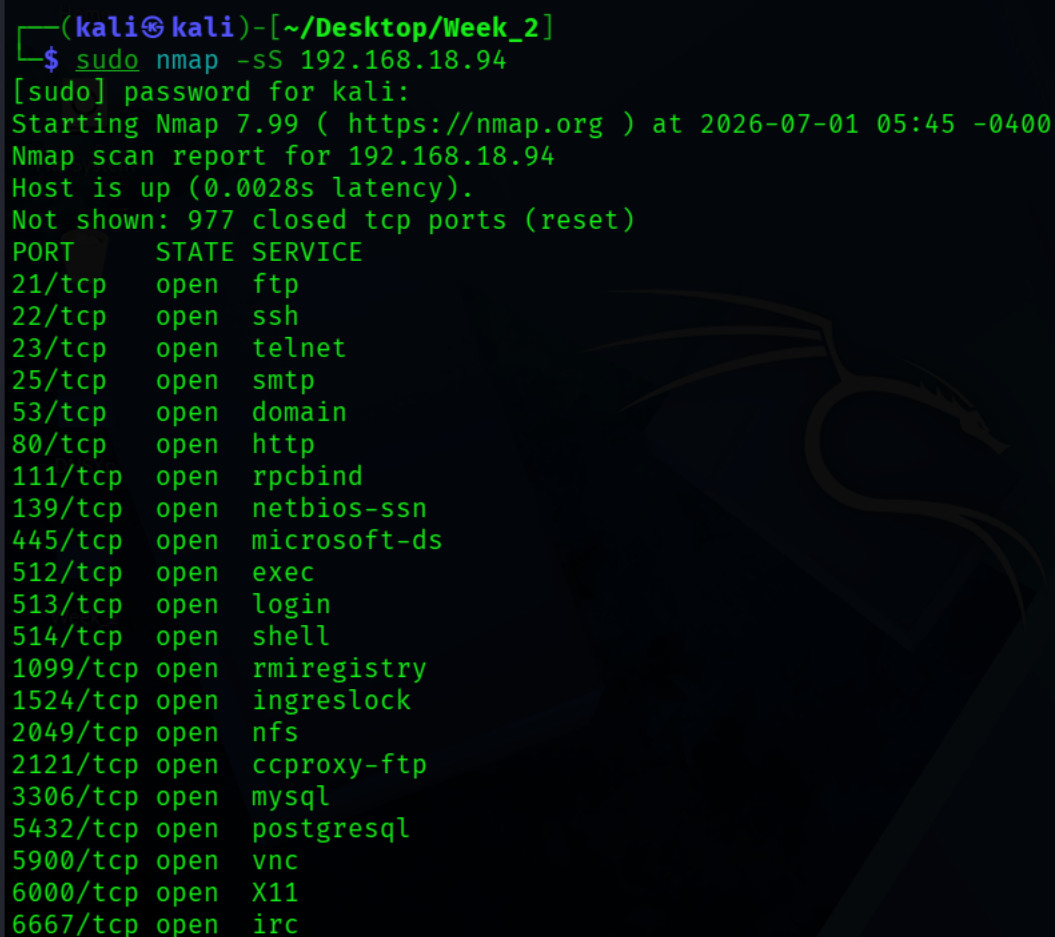
7.3 - COMMANDS & EXECUTION

Step 1 - Normal SYN Scan (Baseline)

Command: `sudo nmap -sS 192.168.18.94`

Purpose: Establish a baseline by identifying open ports without specific evasion flags.

Screenshot: Nmap output showing open ports for the baseline scan



```
(kali㉿kali)-[~/Desktop/Week_2]
$ sudo nmap -sS 192.168.18.94
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 05:45 -0400
Nmap scan report for 192.168.18.94
Host is up (0.0028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
```

Step 2 - Packet Fragmentation Scan

Command: `sudo nmap -sS -f 192.168.18.94`

Purpose: Splits packets into smaller fragments to potentially bypass simple packet filters that inspect only the first fragment.

Screenshot: Nmap output confirming completion of the fragmented scan

```
(kali㉿kali)-[~/Desktop/Week_2]
$ sudo nmap -sS -f 192.168.18.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 05:45 -0400
Nmap scan report for 192.168.18.94
Host is up (0.0041s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
```

Step 3 - MTU Manipulation Scan

Command: `sudo nmap -sS --mtu 16 192.168.18.94`

Purpose: Forces packet sizes to be extremely small (16 bytes), compelling the network stack to fragment data differently.

Screenshot: Nmap output showing the results of MTU-modified traffic

```
(kali㉿kali)-[~/Desktop/Week_2]
$ sudo nmap -sS -mtu 16 192.168.18.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 05:49 -0400
Stats: 0:00:56 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 11.20% done; ETC: 05:58 (0:07:24 remaining)
Stats: 0:05:12 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.50% done; ETC: 06:03 (0:08:40 remaining)
Stats: 0:06:04 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 54.35% done; ETC: 06:00 (0:05:05 remaining)
Stats: 0:09:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 67.40% done; ETC: 06:03 (0:04:25 remaining)
Stats: 0:11:32 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 73.90% done; ETC: 06:05 (0:04:04 remaining)
Stats: 0:19:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 94.30% done; ETC: 06:09 (0:01:09 remaining)
Nmap scan report for 192.168.18.94
Host is up (0.020s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
110/tcp   closed pop3
111/tcp   open  rpcbind
113/tcp   closed ident
135/tcp   closed msrpc
139/tcp   open  netbios-ssn
143/tcp   closed imap
443/tcp   closed https
445/tcp   open  microsoft-ds
```

Step 4 - Decoy Scanning

Command: Sudo nmap -sS -f -D RND:5 -T4 192.168.18.94

Purpose: Generates 5 random decoy IP addresses to obscure the real source of the scan.

Screenshot: Execution of decoy scan demonstrating multiple source IPs.

```
(kali㉿kali)-[~/Desktop/Week_2/detection/nmap-vuln]
$ nmap -sS -f -D RND:5 -T4 192.168.18.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 05:19 -0400
Nmap scan report for 192.168.18.94
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
```

Verify Decoy Scanning Wireshark

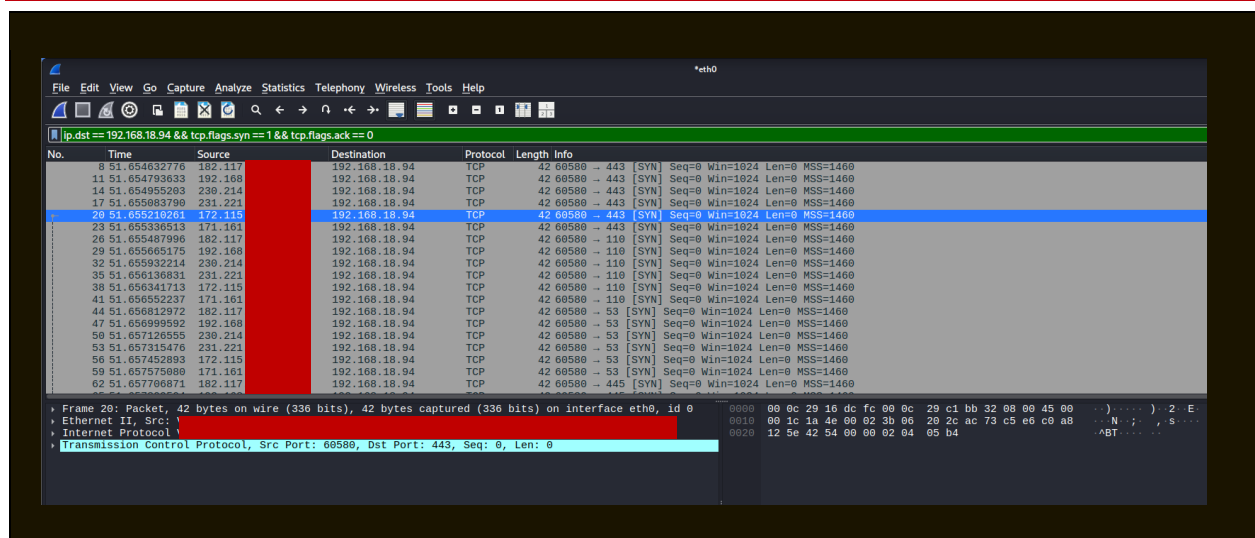
```
Fikter: sudo nmap -sS --source-port 53 192.168.18.94
```

Purpose: This filter isolates initial SYN scan packets sent specifically to the target (192.168.18.94). Its goal is to let you inspect the Source IP column in Wireshark:

Success: You see multiple different Source IPs (1 real + 5 decoys), confirming the decoy scan is working.

Failure: You see only 1 Source IP (your real IP), meaning the local network dropped the spoofed decoy packets.

Screenshot:



Step 5 - Source Port Manipulation

Command: `sudo nmap -sS --source-port 53 192.168.18.94`

Purpose: Sets the source port to 53, making the scan traffic appear as trusted DNS traffic to bypass port-based firewall rules

Screenshot: Execution of scan using source port 53

```
(kali㉿kali)-[~/Desktop/Week_2/detection/nmap-vuln]
$ nmap -sS --source-port 53 192.168.18.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 05:34 -0400
Nmap scan report for 192.168.18.94
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
```

7.4 - KEY FINDINGS

Scan Type	Command	Scan Time	Ports Found	Notes
Normal	<code>sudo nmap -sS</code>	0.95s	23	Baseline scan, fast and accurate.
Fragmented	<code>sudo nmap -sS -f</code>	1.00s	23	Similar to normal; simple filters bypassed.
MTU Modified	<code>sudo nmap -sS --mtu 16</code>	1266.72s	11	Very noisy, extremely slow, caused filtered ports.
Source Port	<code>sudo nmap -sS --source-port 53</code>	0.91s	23	Bypassed port-based rules; fast execution.

7.5 - ANALYSIS & IMPACT

The execution of these evasion techniques against the target (192.168.18.94) provides significant insight into the relationship between network security controls and attacker behavior.

- Analysis of Evasion Efficacy:** * The **Source Port Manipulation (--source-port 53)** proved to be the most effective strategy. It maintained high speed while successfully bypassing firewall rules designed to restrict unauthorized traffic. This demonstrates that many legacy or simple firewalls prioritize traffic based on port origin rather than packet content.
 - The **Fragmentation and MTU Manipulation** techniques confirmed that while packet splitting is a classic evasion method, modern network stacks are often sophisticated enough to reassemble traffic. The extreme performance degradation observed with `--mtu 16` indicates that forcing overly small packets can inadvertently trigger network congestion, making the scan highly "noisy" and counter-productive for stealth operations.
 - The **Decoy Scan** highlighted the ability to inject noise into target logs, complicating the defender's ability to isolate the source of the traffic.
- Impact:** The ability to conduct "quiet" scans is a cornerstone of professional Red Teaming. By utilizing creative packet crafting, an attacker can map the entire attack surface of a system without triggering security alerts that lead to IP blocking or session termination. The target's failure to restrict DNS-based traffic or reassemble fragmented packets effectively reveals a vulnerability in its defense-in-depth posture.

RED TEAM INSIGHT

From a Red Team perspective, the results of this engagement highlight a critical truth: security is only as strong as its configuration. While fragmentation and MTU manipulation are textbook techniques for bypassing simple packet filters, their tendency to cause network latency or packet loss often makes them "noisy" and easily detectable by modern traffic analysis tools. In contrast,

the success of Source Port Manipulation underscores a common oversight in perimeter security, where administrative trust is often blindly placed in specific ports like DNS (53) or HTTP (80). For a Red Team operator, this represents a significant "Initial Access" advantage; by blending malicious traffic into what the firewall perceives as "known-good" service flows, an attacker can enumerate the internal network surface with a high degree of confidence. This serves as a reminder that robust defense-in-depth requires transitioning away from simple port-based access control toward stateful, content-aware inspection, as relying solely on port filtering leaves the door wide open for sophisticated evasion.

8. KEY FINDINGS SUMMARY

Task	Core Finding	Outcome
Task 01	SYN Stealth scan (<code>-sS</code>) performs better than TCP Connect (<code>-sT</code>).	Optimal speed and stealth achieved.
Task 02	Service version detection is the key to finding CVEs.	Identified vulnerable service versions.
Task 03	NSE scripts automate vulnerability discovery effectively.	Mapped findings to specific CVE IDs.
Task 04	Source port spoofing bypasses simple firewall filters.	Bypassed rules while maintaining scan integrity.

9. RISK ASSESSMENT

Risk Level	Vulnerability/Observation	Potential Impact
Critical	Outdated services (e.g., vsFTPD 2.3.4).	Direct risk of Remote Code Execution (RCE).
High	Clear-text protocols (Telnet, FTP, RSH).	Sensitive data theft and session hijacking.
Medium	Weak firewall configuration (port-based filtering).	Evasion of perimeter defenses by attackers.
Low	Unused open ports (e.g., 512, 513).	Increased attack surface for reconnaissance.

10. RECOMMENDATIONS

Task	Area	Recommendation
Task 01	Scanning	Always prefer SYN Stealth (-sS) over TCP Connect (-sT) to avoid excessive log entries.
Task 02	Fingerprinting	Utilize service version detection (-sV) to map services to known CVE databases.
Task 03	NSE	Automate vulnerability assessment using nmap --script=vuln to identify critical weaknesses faster.
Task 04	Evasion	Implement stateful packet inspection to block port-based evasion (e.g., --source-port 53).

11. CONCLUSION

The completion of Tasks 01 through 04 has provided a comprehensive understanding of the reconnaissance phase in a Red Teaming engagement.

- **Task 01 & 02** established that effective scanning requires a balance between speed and stealth, and that accurate service identification is the foundation of any exploitation effort.
- **Task 03** demonstrated the power of automation through the Nmap Scripting Engine (NSE), proving that modern security assessments rely heavily on identifying known vulnerabilities rather than manual discovery.
- **Task 04** highlighted the vulnerabilities in perimeter security, showing how simple firewall rules are easily bypassed by creative packet manipulation.

Ultimately, these tasks illustrate that successful Red Teaming is not just about finding open ports, but about understanding how systems react to traffic. By mastering these Nmap techniques, an operator can identify high-impact risks while remaining undetected, ultimately helping organizations harden their infrastructure against real-world threats.

All findings are documented for educational purposes as part of the CyberSter Red Team Internship Program, Batch 2026, under the instruction of Umar Niaz.

12. APPENDIX - COMMANDS REFERENCE

TASK 01 Advanced Network Scanning with Nmap

```
TCP Connect Scan: sudo nmap -sT 192.168.18.94  
SYN Stealth Scan: sudo nmap -sS 192.168.18.94  
UDP Scan (Top 100): sudo nmap -sU --top-ports 100 192.168.18.94  
Timing Template: sudo nmap -sS -T4 192.168.18.94
```

TASK 02 Service Fingerprinting & Banner Grabbing

```
Service Version Detection: sudo nmap -sV 192.168.18.94  
Aggressive Scan (OS + Version + Script): sudo nmap -A 192.168.18.94  
Banner Grabbing (Manual): nc 192.168.18.94 21 (FTP banner capture).
```

TASK 03 Leveraging Nmap Scripting Engine (NSE)

```
Vulnerability Scan: sudo nmap -sV --script=vuln 192.168.18.94  
Safe/Default Script Scan: sudo nmap -sC 192.168.18.94  
Specific Service Script: sudo nmap -p 445 --script=smb-vuln* 192.168.18.94
```

TASK 04 Stealth & Firewall Evasion Techniques

```
Packet Fragmentation: sudo nmap -sS -f 192.168.18.94  
MTU Manipulation: sudo nmap -sS --mtu 16 192.168.18.94  
Decoy Scanning: sudo nmap -sS -D RND:5 192.168.18.94  
Source Port Spoofing: sudo nmap -sS --source-port 53 192.168.18.94
```

End of Week 02: Network Enumeration & Service Vulnerability Discovery Report
CyberSter Red Team Internship Program | Daniyal Shahid | CYB-INT-HQYINF | Batch 2 (2026)